CYBER SECURITY TASK 1

Read-Only Website Vulnerability Assessment

wellnessdiagnosticcenter.in

A point-in-time review of public pages and response configuration

ASSESSMENT WINDOW	ASSESSOR / AUTHORIZATION
29-30 October 2026	Requester identified this as their own website
METHOD	OVERALL RESULT
OWASP ZAP 2.17.0, Safe Mode, passive alerts during manual browsing	No High alerts. Medium configuration findings require review; no exploit was validated.

Prepared for the Future Interns Cyber Security Task 1. This report records the evidence visible in the supplied ZAP session and does not claim a full penetration test or a guarantee that the website is secure.

1. Executive summary

The public site was browsed manually through Firefox with OWASP ZAP 2.17.0 in Safe Mode. ZAP recorded 11 alerts in this session: 4 Medium, 2 Low, and 5 Informational. There were no High alerts. The Medium alerts point to security-header and resource-configuration items. The available evidence does not demonstrate account compromise, cross-site scripting, patient-data disclosure, or an exploitable CORS issue.

11	0	4	2	5
ZAP alerts	High	Medium	Low	Info

Priority actions

1. Test and deploy a site-specific Content Security Policy, beginning in report-only mode.
2. Add a frame-ancestors policy that matches the site's legitimate embedding needs.
3. Review CORS rules on authenticated or private API responses; the observed wildcard was on a public static JavaScript file.
4. Add X-Content-Type-Options: nosniff and confirm each response uses the correct Content-Type.
5. Keep patient-specific responses out of shared caches and avoid putting sensitive records or tokens in browser localStorage.

Scope and method

Targets visible in the ZAP site tree were the apex and www HTTPS site. Testing consisted of manual browsing of public pages and passive review of observed responses and alerts. A browser-storage alert was reviewed in the test browser. Third-party Unsplash content was only observed as a resource reference and was not assessed.

Not tested

No Nmap scan, active ZAP scan, exploitation, spidering campaign, login or patient portal, authenticated API, appointment/payment action, brute force, denial-of-service, source-code review, server configuration review, or patient-data access was performed. This is a limited passive review, not a penetration test or certification.

2. Findings - security headers

The following two Medium alerts relate to missing browser security controls on the sampled homepage response.

F-01 Content Security Policy header not set

ZAP: Medium (High confidence)

Context Homepage response at https://www.wellnessdiagnosticcenter.in/.

Observed evidence ZAP's sampled response did not include a Content-Security-Policy header.

Why it matters Without a policy, the browser has less guidance about which sources are allowed to load. A policy can reduce the impact of some content-injection bugs, but this scan did not test for or demonstrate XSS.

Recommended action Create a policy based on the site's actual scripts, styles, images, fonts, and API connections. Deploy Content-Security-Policy-Report-Only first, review violations, then enforce a tested policy.

Validation limit Passive header check only. No injection payloads or application workflows were tested.

F-02 Clickjacking protection header missing

ZAP: Medium (Medium confidence)

Context Homepage response at https://www.wellnessdiagnosticcenter.in/.

Observed evidence ZAP reported no X-Frame-Options header and no CSP frame-ancestors directive in the sampled response.

Why it matters If a page with user actions can be embedded by another site, a user could be tricked into clicking controls. No framing proof-of-concept or sensitive action was tested.

Recommended action Set Content-Security-Policy: frame-ancestors 'none' if the site must not be embedded, or list the exact allowed origins if embedding is required. Consider X-Frame-Options as a compatibility fallback.

Validation limit No login, patient, appointment, or payment workflow was tested. Confirm intended embedding before choosing the policy.

3. Findings - cross-origin and external resources

F-03 Wildcard CORS on a public JavaScript asset

ZAP: Medium (Medium confidence)

Context Static asset: /_next/static/chunks/webpack-080e3fb35cd04c97.js.

Observed evidence The response included Access-Control-Allow-Origin: * on a public, versioned JavaScript chunk.

Why it matters A wildcard on a public static file does not by itself expose private data. The risk would be different if a sensitive API response were readable cross-origin.

Recommended action Keep wildcard access only where content is intentionally public. Review private API routes separately and allow only required origins; do not reflect arbitrary Origin values.

Validation limit Only the static asset response was observed. Authenticated APIs, credentialed CORS, and sensitive responses were not tested.

F-04 SRI attribute missing on external image preload

ZAP: Medium (High confidence)

Context Homepage HTML referenced an image hosted by images.unsplash.com.

Observed evidence The evidence was a link rel=preload as=image element for an external image, not an external JavaScript file.

Why it matters The alert is a supply-chain observation. The captured evidence does not show executable third-party code or an exploit path.

Recommended action Review whether the external image is approved and necessary. Apply SRI to stable external scripts or styles where supported. Do not treat this image-only evidence as a script integrity failure.

Validation limit The external provider was not tested. Dynamic image URLs may change and make integrity hashes impractical.

Interpretation

ZAP assigned Medium severity to both alerts. The evidence narrows their demonstrated impact: CORS was seen on a public static file, and the SRI alert was for an image preload. Treat them as review items, not proof of data exposure or code execution.

4. Findings - low and informational

F-05 X-Content-Type-Options missing

ZAP: Low

Context ZAP marked this response-header issue as systemic.

Observed evidence The sampled response did not set X-Content-Type-Options: nosniff. The visible responses declared Content-Type values; no MIME mismatch was demonstrated.

Why it matters Some browsers may otherwise infer a resource type in certain contexts, which can increase risk if content is served with the wrong type.

Recommended action Set X-Content-Type-Options: nosniff for appropriate responses, and ensure every resource has the correct Content-Type.

Validation limit Passive header review only; no MIME-sniffing exploit was tested.

F-06 Browser localStorage flagged as sensitive

ZAP: Low (ZAP); no sensitive value observed

Context The test browser reported the key wellness_users_database_v5.

Observed evidence The captured value was an empty array: []. ZAP also raised an informational alert for the same browser-storage key.

Why it matters Browser storage is accessible to page scripts. The captured value contains no patient or personal records, so this evidence does not confirm sensitive-data exposure.

Recommended action Do not store patient records, secrets, or long-lived tokens in localStorage. If application data is needed, minimize it and enforce server-side authorization. Recheck only with synthetic test data.

Validation limit This describes one test browser state only. It says nothing about other users, sessions, or authenticated pages.

Informational alerts

Alert	Observed evidence and treatment
Browser localStorage information	The key wellness_users_database_v5 had value []. No sensitive value was demonstrated in this captured browser state.
Suspicious comments	A pattern matched the word query in minified JavaScript. No secret or exploitable comment was confirmed; treat as unverified/informational.
Modern Web Application	Technology fingerprint only. It is not a vulnerability by itself.
Re-examine Cache-control	Homepage showed Cache-Control: public, max-age=0, must-revalidate. This permits storage but requires revalidation; no personalized response was observed.
Retrieved from Cache	A public, versioned JavaScript asset showed Age: 254843 and Cache-Control: public, max-age=31536000, immutable. This is consistent with long caching for fingerprinted public assets.

Caching recommendation

Do not change long-lived caching for public hashed assets based on this alert alone. For any future authenticated or patient-specific response, verify that caching is private or disabled as appropriate; this assessment did not examine those responses.

5. Remediation plan and conclusion

Priority	Action	How to confirm
1 - High value	Draft a tailored CSP and frame-ancestors policy. Start in report-only mode and preserve legitimate site resources and embeds.	Review browser/report-only violations, then confirm enforced response headers on public pages.
2 - High value	Review CORS on API routes that may return private or user-specific data. Keep only necessary origins.	Check each approved API response and confirm that private data is not readable from untrusted origins.
3 - Standard	Add X-Content-Type-Options: nosniff and keep Content-Type accurate.	Inspect representative HTML, JavaScript, CSS, and error responses.
4 - Privacy	Keep patient-specific content out of localStorage and shared caches.	Using an authorized synthetic account, inspect storage and cache headers for authenticated pages. No such retest is included here.
5 - Review	Confirm whether external image hosting is approved. Apply SRI to stable scripts/styles where it is supported and useful.	Review the actual resource type and whether it changes. Do not apply a fixed hash to a changing image URL.

Conclusion

The passive session identified missing browser security headers and several lower-confidence or informational observations. The strongest immediate improvements are a carefully tested CSP and framing policy, plus nosniff. The CORS and SRI alerts need context-specific review because the observed resources were public static JavaScript and an external image preload. No High alerts or confirmed exploitation were observed. This result is limited to the pages and browser state examined on 29-30 October 2026.

References

MDN - Content Security Policy | MDN - frame-ancestors | MDN - Clickjacking
MDN - X-Content-Type-Options | MDN - Subresource Integrity | MDN - Cache-Control
OWASP WSTG - CORS testing

Appendix A. ZAP screenshots

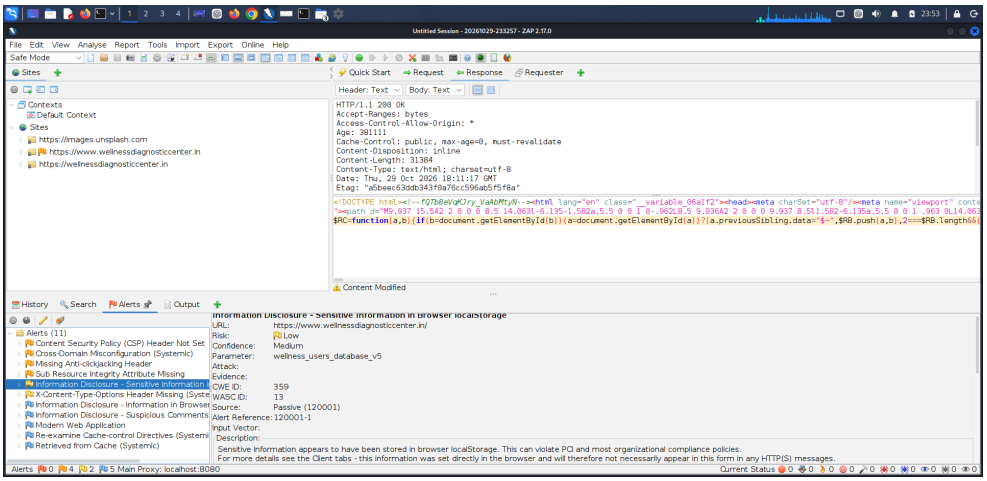
All ZAP screenshot evidence supplied during this assessment is mapped in the register below. Five representative ZAP captures are reproduced after the register. Include the original screenshots in the public repository's evidence folder alongside this report.

Evidence	Screenshot supplied	Supports
E-00	Screenshot_2026-10-29_23_42_02.png	ZAP session and alert inventory (11 alerts).
E-01	Screenshot_2026-10-29_23_43_38.png	F-01 - CSP header not set.
E-02	Screenshot_2026-10-29_23_44_57.png	F-03 - wildcard CORS on public JavaScript.
E-03	Screenshot_2026-10-29_23_49_24.png	F-02 - missing anti-clickjacking header.
E-04	Screenshot_2026-10-29_23_51_48.png	F-04 - SRI alert on external image preload.
E-05	Screenshot_2026-10-29_23_53_52.png	F-06 - localStorage alert.
E-06	Screenshot_2026-10-29_23_56_36.png	F-05 - missing X-Content-Type-Options.
E-07	Screenshot_2026-10-29_23_57_38.png	Informational browser localStorage alert.
E-08	Screenshot_2026-10-29_23_58_20.png	Informational suspicious-comments alert.
E-09	Screenshot_2026-10-29_23_59_21.png	Informational homepage Cache-Control alert.
E-10	Screenshot_2026-10-30_00_00_28.png	Informational Retrieved from Cache alert.

Embedded screenshot extracts

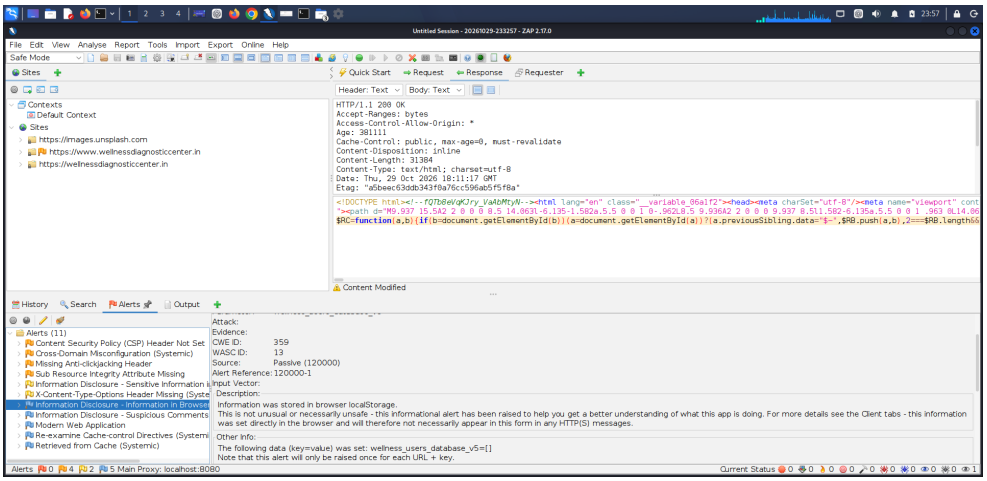
The captures below illustrate the local-storage, suspicious-comments, and cache observations. The evidence register maps each other finding to its matching original screenshot.

Evidence A1 - Sensitive localStorage alert



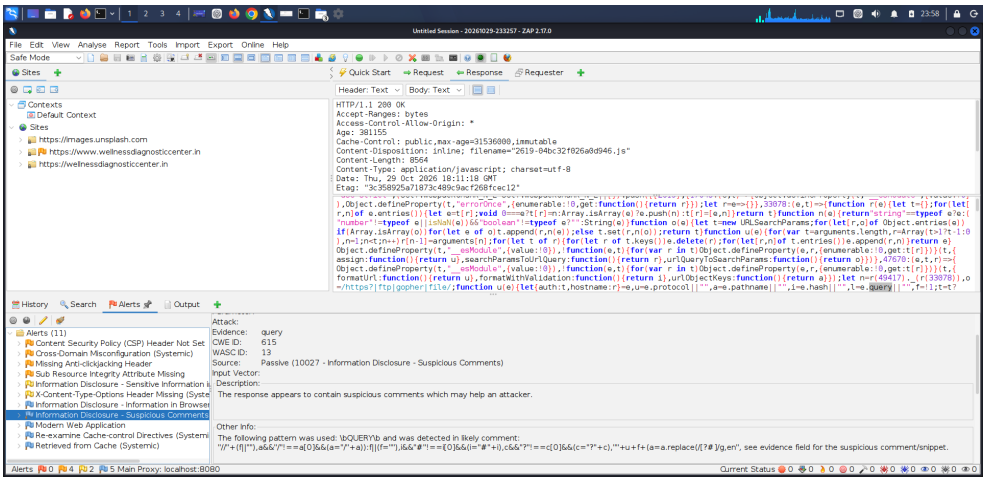
ZAP marked the browser storage observation as Low. The later captured value for the key was an empty array; do not infer contents for other sessions.

Evidence A2 - Informational localStorage alert



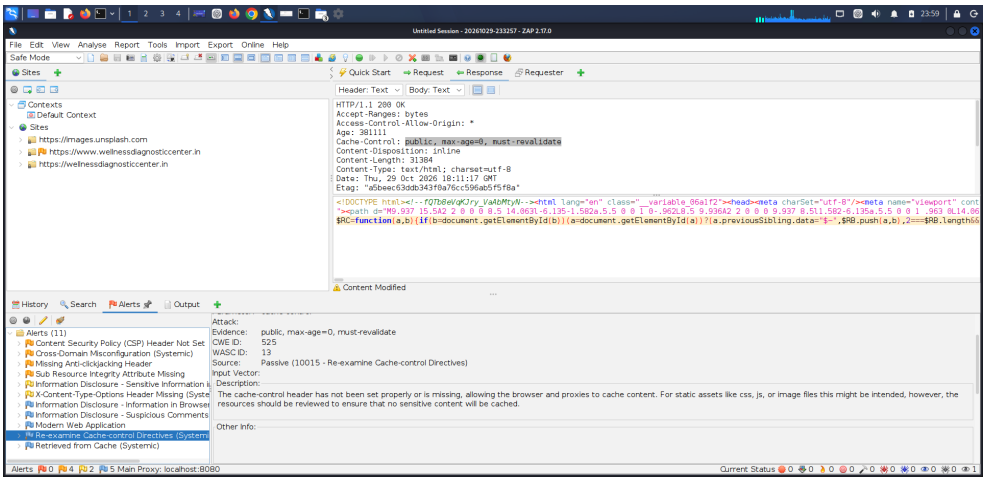
Informational observation of client-side browser storage. This is not a confirmation of patient-data disclosure.

Evidence A3 - Suspicious comments alert



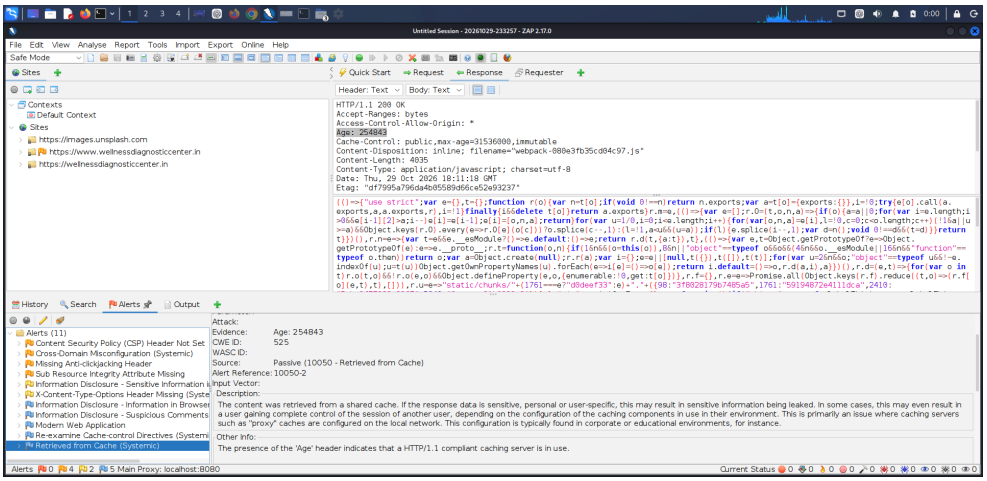
ZAP matched a pattern in minified JavaScript. The alert evidence did not establish a secret or exploitable issue.

Evidence A4 - Re-examine Cache-control



The homepage response showed public, max-age=0, must-revalidate.

Evidence A5 - Retrieved from Cache



The versioned JavaScript asset showed Age: 254843 and public, max-age=31536000, immutable.